

Actividad 4: Escaneo de Seguridad con OWASP ZAP

Tema: *Identificación de vulnerabilidades con OWASP ZAP*



Objetivo: *Usar OWASP ZAP para encontrar y corregir vulnerabilidades en una aplicación*

¿Qué es OWASP ZAP?

ZAP (Zed Attack Proxy) es una herramienta de **escaneo de seguridad dinámica** que detecta vulnerabilidades como **XSS**, **SQLi** y configuraciones inseguras. <https://www.zaproxy.org/>

Instalar OWASP ZAP

```
sudo apt install zaproxy
```

Verificar la instalación:

```
zaproxy -daemon -port 8080 -host 127.0.0.1
```

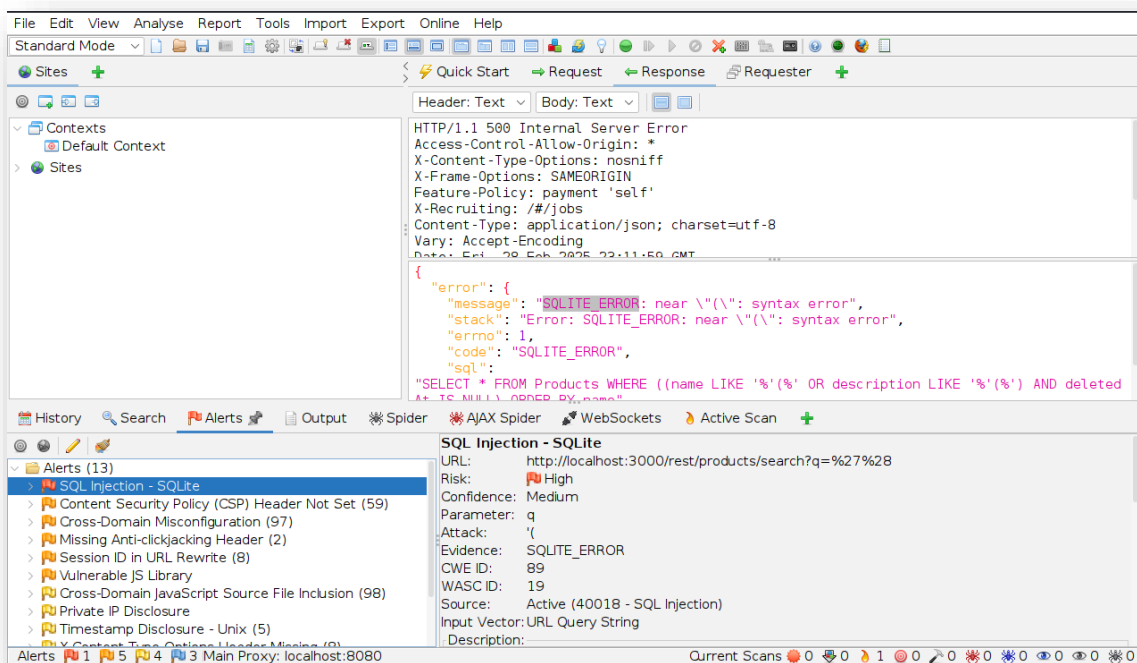
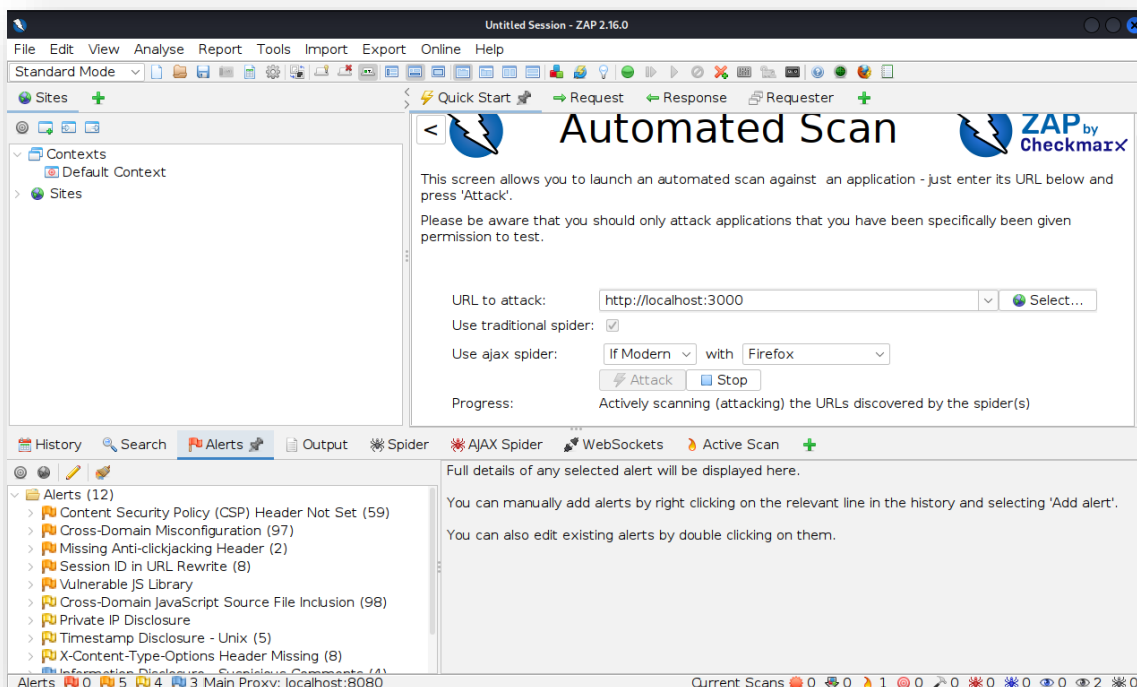
Ejecutar un escaneo contra una aplicación web

Iniciar ZAP y configurar un escaneo contra *OWASP Juice Shop*:

1. Abrir OWASP ZAP.
2. Ingresar la URL de la aplicación vulnerable *OWASP Juice Shop* en: `http://localhost:3000`
3. Seleccionar "**Escaneo Automático**" y ejecutar el análisis.

Ejemplo de vulnerabilidad detectada:

- Reflected XSS in /search?q=<script>alert('XSS')</script>
- SQL Injection possible in /login



Mitigación y Mejores Prácticas

- Revisar el informe de ZAP y corregir vulnerabilidades detectadas.
- Automatizar escaneos en CI/CD para detectar fallos antes del despliegue.